Critical-but-Fragile: Mapping Fragility Across Functional Categories of Open Source Infrastructure

Sarah Novotny

ECP77594 — Computational Methods in Economics — Final Project

1. Introduction and research question

The European software sector — Eurostat NACE J62/J63 — produced EUR 467 billion in gross value added in 2022. A large share of that value rests on a substrate of open source software (OSS) packages that are downloaded, depended on, and shipped into production by firms that contribute little or nothing to their maintenance. The Apache Log4j incident of December 2021 made the consequences visible: a single-maintainer Java logging library, embedded in commercial products worldwide, propagated a remote-code-execution vulnerability into critical infrastructure within days. The maintainer had been working on the project unpaid in his free time.

The standard framing of this problem is a Samuelsonian public goods story: OSS is non-rival and non-excludable, so the market under-provides it. That framing has the wrong empirical content. Much of critical OSS is *not* under-provided: popular packages attract maintainers and contributor communities that grow with downstream use. That attention is often guided by corporate self-interest and not preventative work. The problem is not uniform. A sharper framing comes from Ostrom (1990): OSS infrastructure is a common-pool resource, governed in practice by community institutions whose success depends on identifiable design conditions. Where those conditions hold, self-organisation works; where they fail, packages become *critical-but-fragile* — load-bearing, but maintained by one or two unpaid people with no institutional awareness or attention (Schweik & English, 2012). The question is then not *whether* OSS is under-provided but *where* governance fails and how much economic value sits above those failures.

This paper asks: **Which functional categories of load-bearing open source infrastructure are most fragile, and what is the order of magnitude of the unmet maintenance funding need above them?** The contribution is methodological rather than substantive. It combines composite criticality and fragility scoring on a 4.6-million-package dependency graph with NMF topic modelling of package descriptions, percentile-based risk-universe identification, and a Monte Carlo bootstrap for inference. The aim is a defensible per-cluster funding-gap minimum value estimate for the EU software sector that policymakers can use to size a targeted backstop, not a precise euro figure.

2. Data and processing

Libraries.io v1.6.0 (Katz, 2020), retrieved from Zenodo, is a snapshot taken on 12 January 2020 covering 4.6 million packages across 36 package managers. For each package the dataset reports name, ecosystem, description, dependent-project and dependent-repository counts, contributor and star counts, open-issue counts, and timestamps for the latest release and last repository push. Anal-

ysis is restricted to seven major ecosystems — npm, Maven, PyPI, NuGet, RubyGems, Packagist, Cargo — producing 2.4 million candidate packages, of which 9,461 meet a *load-bearing* threshold of at least 100 dependent projects. This threshold is conservative; it identifies packages whose failure would propagate to a non-trivial number of downstream consumers.

Eurostat National Accounts (`nama_10_a64`, B1G — Gross Value Added at current prices, NACE J62_J63 — Computer programming, consultancy, data processing) provides the economic context: EUR 466,568 million across 31 countries in 2022. The series is fetched once via DBnomics and cached locally. EU aggregates (EU27, EA19, etc.) are excluded to avoid double-counting member states.

Processing and reproducibility. A separate `preprocess.py` script handles the cleaning. Two operational fixes are documented in `PROJECT_OVERVIEW.md`: an off-by-one CSV header correction, and imputation of missing contributor counts (28% of load-bearing packages) as 1, treating missingness as evidence of under-resourcing rather than dropping a quarter of the sample. Days since release are imputed at the 90th percentile when both release and push timestamps are missing.

The preprocessing step writes a 1.9 MB analysis-ready CSV (`data/packages_loadbearing.csv`) and a 31-row Eurostat cache. All subsequent analysis runs offline and deterministically against these files; the random seed (`42`) is propagated to the NMF, the LASSO cross-validation split, and the bootstrap RNG.

3. Methods

Criticality. A composite score in [0, 1] computed from Libraries.io dependent-project and dependent-repository counts:

$$C = \text{norm}\left(0.65 \cdot \text{norm}(\log(1 + d_{pkg})) + 0.35 \cdot \text{norm}(\log(1 + d_{repo}))\right)$$

where `norm` is min-max scaling. The log transform reflects the heavy-tailed distribution of dependent counts (a handful of packages have tens of thousands of dependents). The 65/35 weighting favours direct package dependencies over repository-level usage, which the Libraries.io documentation reports more conservatively.

Fragility. A weighted additive composite of four min-max normalised indicators:

$$F = \text{norm}\left(0.30 \cdot f_{contrib} + 0.30 \cdot f_{stale} + 0.20 \cdot f_{issues} + 0.20 \cdot f_{busfactor}\right)$$

with $f_{contrib} = 1/\text{contributors}$; $f_{stale} = \log(1 + \text{days since release})$; $f_{issues} = \frac{\text{open_issues}}{\max(\text{stars}, 1)}$; and $f_{busfactor} = \mathbb{1}[\text{contributors} < 2]$. An additive form is used over a multiplicative one to avoid zero-inflation collapsing the score whenever any single component is zero.

Risk universe. Packages above the 75th percentile on *both* criticality and fragility. The 75th percentile is a conventional financial Value-at-Risk threshold. A sanity check confirms construct validity: `log4j:log4j` (the Log4Shell package) sits comfortably inside the risk universe at C = 0.625, F = 0.903.

Topic modelling. Package descriptions are vectorised with TF-IDF after URL stripping, markdown-image removal, and an 80-term domain stop-word list (artifact types, platform identifiers, marketing filler) added on top of sklearn's English stop words. Non-negative matrix factorisation (Lee & Seung, 1999) is preferred over LDA because package descriptions are typically a single sentence of technical jargon — too short for LDA's generative assumptions but well-suited

to NMF's non-negative additive decomposition. The analysis uses a two-pass NMF design. In the first pass, NMF is fit on all 9,461 load-bearing packages ($k = 25$, selected by topic-quality inspection: no cluster exceeds 9.8% and topics resolve into recognisable functional categories). The reconstruction-error curve has no sharp elbow, so the choice rests on interpretability. Two of the 25 corpus clusters (Topics 0 and 24) are *residual* — they collect packages with descriptions too generic for NMF to assign elsewhere when vocabulary is shaped by the full corpus.

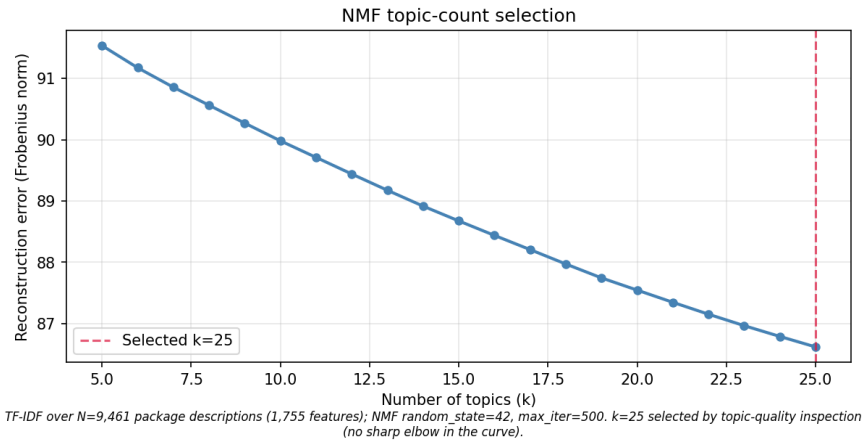

Figure 1: Full-corpus NMF topic-count selection. Reconstruction error decreases monotonically with no sharp elbow; $k = 25$ chosen by topic-quality inspection.

In the second pass, TF-IDF and NMF are re-fitted on the 247 risk-universe packages only, using a vocabulary constrained to the risk set ($k = 5$, sweep $k = 3 \ldots 8$, Figure 0b). This avoids the bleeding of full-corpus npm signal into the risk-set topic structure. With the vocabulary constrained to 268 features, all five topics resolve into coherent functional categories; neither residual cluster appears.

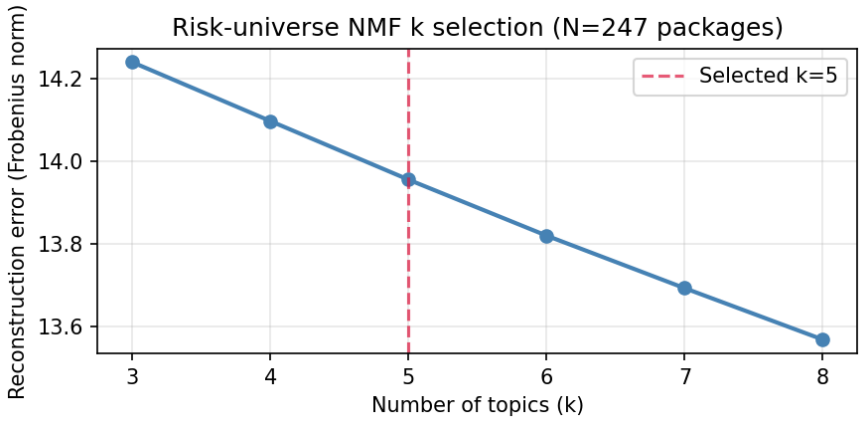

Figure 2: Risk-only NMF topic-count selection. Reconstruction error across $k = 3 \ldots 8$ for the 247 risk-universe packages; $k = 5$ chosen by interpretability — splits Microsoft/.NET from HTTP/web utilities while keeping all clusters ≥ 14 packages.

LASSO validation. Cross-validated LASSO regression of the bus-factor flag on observable features provides directional validation of the fragility weights. The procedure is partially circular and is used as a sanity check only, not to set weights.

Bootstrap inference. 1,000 Monte Carlo replicates resample the 9,461 packages with replacement, recomputing the 75th-percentile thresholds and risk-universe size on each replicate. Confidence intervals are percentile-based (Efron & Tibshirani, 1993).

Funding gap. A gross lower bound: 2 FTEs per risk-universe package at the EU median software developer salary of EUR 45,000/year (EUR 90,000 per package per year). The 2-FTE floor is drawn from OpenSSF guidance on minimum viable maintenance staffing — one for active development, one for security response and bus-factor redundancy. The estimate is conservative on four dimensions (sub-market salary, uniform staffing, no offset for existing funding, conservative percentile threshold), all pushing in the same direction.

4. Results

Risk universe. Of 9,461 load-bearing packages, 247 (2.6%) lie above the 75th percentile on both criticality and fragility. The Pearson correlation between criticality and fragility is $r = -0.31$ ($p < 10^{-200}$, Spearman $\rho = -0.26$): more critical packages tend to be *less* fragile. This is the central empirical finding of the paper. The market, as represented in this case by the community-governance institutions Ostrom predicts, partly works: visible, widely-used packages attract maintainers. The 247 packages in the risk universe are the exceptions, the cases where governance has not self-organised despite high downstream usage.

Figure 2 shows the full distribution; the risk universe sits in the upper-right quadrant, coloured by risk-only functional cluster.

Cluster ranking. A second NMF pass fit only on the 247 risk-universe packages identifies five functional categories. Table 1 ranks all five by mean fragility; Figure 3 shows the ranking and per-cluster funding gap.

Cluster	N	Mean F	% bus factor = 1
Apache / Java Commons legacy infrastructure	27	0.721	74.1%
Microsoft / .NET + npm ecosystem	127	0.606	51.2%
HTTP & web protocol utilities	35	0.563	42.9%
Gulp / JS build & task tooling	44	0.543	38.6%
Karma / JS test runners	14	0.486	28.6%

The most fragile cluster — Apache / Java Commons legacy infrastructure — comprises 27 Maven packages including `log4j:log4j` (F=0.903), `commons-lang:commons-lang` (F=0.909), and `commons-logging:commons-logging` (F=0.892), each maintained by a single contributor despite thousands of downstream dependents. Unlike a corpus-level analysis, no residual cluster appears: constraining the vocabulary to the 247-package risk set produces descriptions informative enough for NMF to assign every package to a coherent functional category. The Microsoft / .NET + npm cluster is the largest (127 packages) and accounts for the dominant share of the funding gap, though its fragility may be partly inflated by a Libraries.io metadata gap for enterprise ecosystems (see §5).

Threshold sensitivity. The risk universe size scales sharply with the chosen percentile threshold: 12 packages at the 90th percentile, 247 at the 75th, 1,146 at the 60th. Because the risk-only NMF (k=5) is fit on each threshold's own risk set, its cluster labels are not comparable across thresholds; stability is therefore checked against the full-corpus k=25 labels. The cluster with the *highest risk*

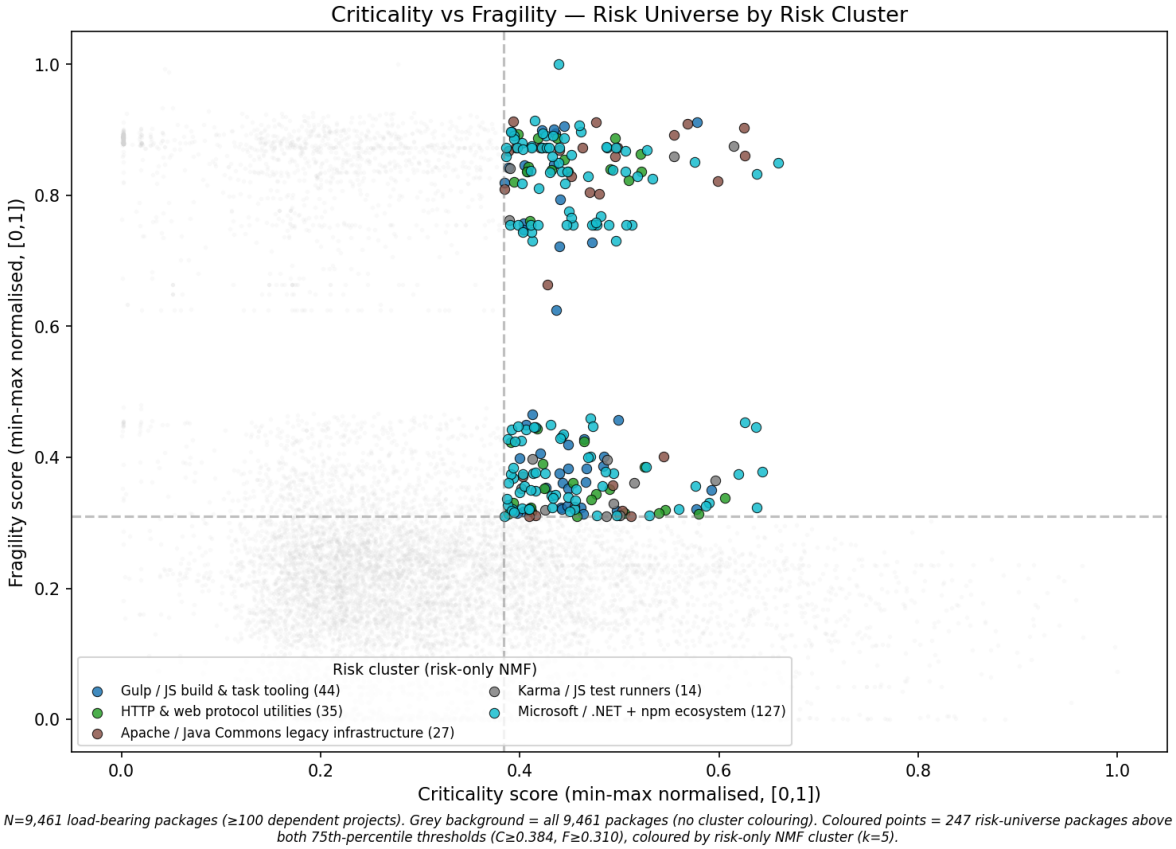

Figure 3: Criticality versus fragility for $N = 9{,}461$ load-bearing packages. Background points in grey (no cluster colouring); risk-universe packages coloured by risk-only NMF cluster. Dashed grey lines mark the 75th-percentile thresholds.

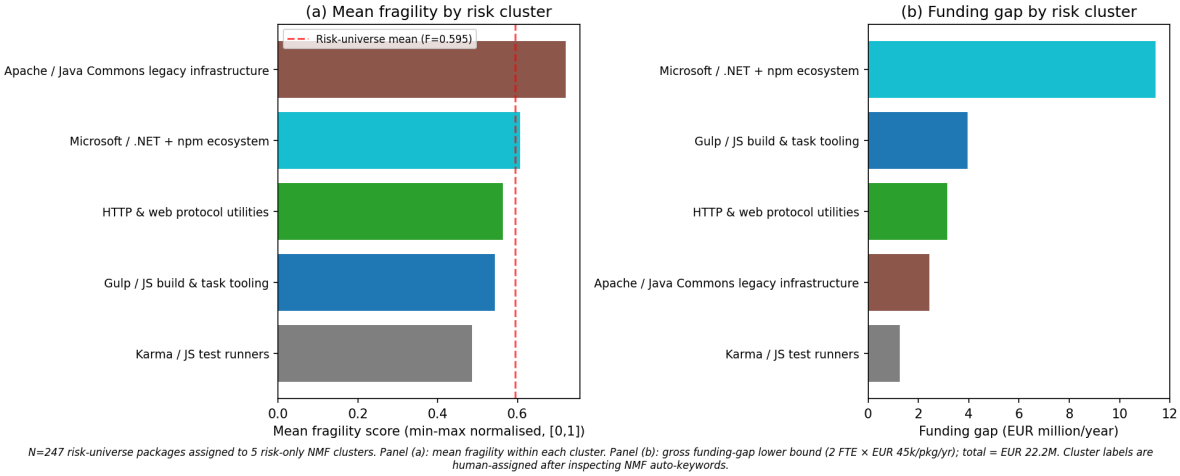

Figure 4: Mean fragility by risk cluster (left panel) and annual funding gap by risk cluster (right panel, EUR millions). All 247 risk-universe packages appear in exactly one cluster.

concentration (share of cluster members in the risk universe) varies by threshold — Command-line infrastructure at the 60th, Task runners (Gulp/Rake) at the 75th, Cloud & API clients at the 90th — so there is no single "most at-risk category" that survives across thresholds. The mean-fragility ranking is more stable than the risk-concentration ranking.

LASSO sanity check. In 5-fold CV, LASSO achieves $R^2 = 0.24$ with `log(stars)` the strongest predictor (coef −0.29), consistent with the C–F correlation; staleness is zeroed out, suggesting the four fragility indicators are partially redundant.

Funding gap. At 2 FTEs × EUR 45,000 per risk-universe package, the gross lower-bound funding gap is **EUR 22.2 million per year [bootstrap 95% CI: 19.7, 24.8]**. The bootstrap CI characterises sampling uncertainty in the risk-universe size only — it does not quantify any of the four specification uncertainties (see Methods), all of which would push the figure upward. By cluster: Microsoft / .NET + npm (127 packages) accounts for EUR 11.4M; Gulp / build tooling EUR 4.0M; HTTP & web protocol utilities EUR 3.1M; Apache / Java Commons legacy EUR 2.4M; Karma / test runners EUR 1.3M. Figure 4 shows the bootstrap distributions for the risk universe size, the funding gap, and the mean fragility of risk-universe packages.

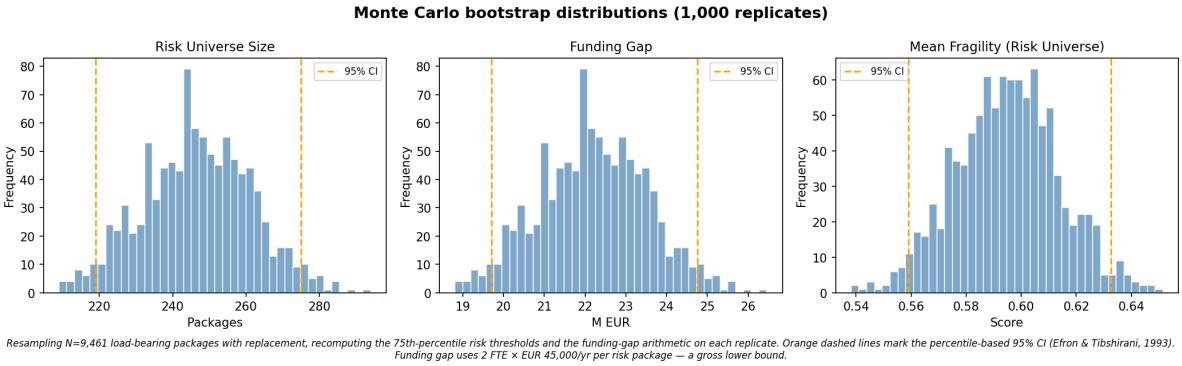

Figure 5: Monte Carlo bootstrap distributions across 1,000 replicates. Orange dashed lines mark the percentile-based 95% confidence intervals.

The funding gap of EUR 22M sits against an EU software-sector GVA of EUR 467 billion. As a fraction of GVA the gap is 0.005% — economically negligible *if it could be paid*. For comparison, Germany's Sovereign Tech Fund disbursed ~EUR 11.5M in 2023 — the gross unmet need identified here is of the same order as existing European public funding for OSS.

5. Discussion

Interpretation through the Ostrom frame. The negative C–F correlation is the paper's most economically interesting result. It rules out the strong-form public-goods reading — "OSS is uniformly under-provided" — and supports a CPR reading — "OSS is variably governed; institutions emerge for visible packages and fail for the rest." The 247 packages in the risk universe are the cases where neither corporate sponsorship nor foundation grants nor community contribution have closed the maintenance gap, despite the package being load-bearing. The policy implication is *targeted backstop*, not wholesale state provision.

Limitations. Five are material.

1. *Bimodal fragility distribution.* The fragility distribution has an empty band between F ≈

0.50 and F $\approx$ 0.60, a specification artifact of the binary bus-factor indicator (contributors $<$ 2): single-maintainer packages receive simultaneous boosts on two score components, so every single-maintainer load-bearing package sits above the 75th-percentile fragility threshold. The risk universe is still filtered by criticality (about half its 247 members have 2+ contributors), but fragility ranking above the gap is driven almost entirely by the bus-factor flip — the operative phase transition for security-response capacity.

2. *Snapshot age.* The Libraries.io snapshot is from January 2020; the OSS landscape has moved (npm growth, Rust adoption, the Log4Shell aftermath) and concrete package-level findings would need a fresh pull to be operationally actionable.
3. *npm-heavy criticality.* Criticality is computed from Libraries.io dependent counts only — npm coverage is more complete than Maven or NuGet because enterprise Java/.NET deployments often use private artifact repositories. The risk universe is therefore npm-heavy (62%); a fully-symmetric analysis would require commercial registry data.
4. *Metadata vs activity.* Fragility is measured from package metadata rather than code or commit history. A package with weekly commits by a single maintainer is not "fragile" in the same sense as one with no activity for two years, but the score conflates them at the high end.
5. *.NET contributor-count artefact.* The Microsoft / .NET + npm cluster (127 packages, 51% of the risk universe by count, EUR 11.4M of the gap) may be substantially inflated by a Libraries.io coverage gap. Enterprise .NET deployments frequently use private artifact registries (Azure Artifacts, internal NuGet servers) that do not report contributor metadata to Libraries.io; contributor counts of 1 in this ecosystem are more likely to be missing data than genuine single-maintainer status. A conservative interpretation of the results should treat the Apache / Java Commons cluster as the most reliable finding and the Microsoft / .NET cluster as an upper-bound estimate requiring validation against NuGet registry data.

Policy implications. The 247 packages identified here are candidates for targeted public funding through institutions modelled on the Sovereign Tech Fund and NLnet — small grants, lightweight oversight, focused on filling the maintenance gap rather than directing development. The cluster-level breakdown is now more actionable than a corpus-level analysis allows: Apache / Java Commons legacy infrastructure is the highest-fragility, most verifiable target (27 packages, F=0.721, 74% single-maintainer); Gulp / build tooling and HTTP / web protocol utilities represent well-defined, tractable clusters in the EUR 3–4M range. The Microsoft / .NET cluster should be validated against NuGet registry data before funding allocation. A formal cost-benefit analysis comparing the EUR 22M lower bound to the avoided cost of Log4Shell-class incidents would extend this work; it is left for follow-up because credible incident-cost data remains fragmentary.

References. Efron & Tibshirani (1993); Eghbal (2016); Katz (2020); Lee & Seung (1999); Nagle et al. (2022); Ostrom (1990); Schweik & English (2012). Full citations in `references.md`.

Reproducibility. All results, tables, and figures are produced by `preprocess.py` followed by `analysis.py` against the inputs documented in `raw_data/README.md`. Random seed = 42 throughout. See `README.md` for run instructions.

Full repository. `<https://github.com/sarahnovotny/CME/tree/main/final_project>`.

AI tool use. Per the module's stated policy on AI assistance, this project used Claude (Anthropic) as a coding and editing collaborator. Concretely: pair-programming on the data-cleaning pipeline (the off-by-one CSV fix, contributor imputation), drafting and iterating the topic-modelling stopword list, refactoring the project layout into the `preprocess.py` / `analysis.py` / `data/` / `outputs/`

separation for reproducibility, and copy-editing this report. All research questions, methodological decisions (criticality and fragility weights, choice of NMF over LDA, $k = 25$ topic count, 75th-percentile risk threshold, lower-bound funding-gap framing), the Ostrom/CPR theoretical framing, and the interpretation of results are the author's. The author is responsible for every claim, number, and figure in this paper.